

MEDIDAS CORRECTORAS RGPD

Artículo 30 ausencia de RAT. La medida correctora es crear y mantener el Registro de Actividades de Tratamiento documentando todos los tratamientos que realiza BERMA: gestión de nóminas, gestión de clientes, gestión de proveedores y acceso remoto a sistemas de clientes. El RAT debe incluir para cada tratamiento la finalidad, la base legal, las categorías de datos, los destinatarios, los plazos de conservación y las medidas de seguridad aplicadas. Salvaguarda Magerit asociada E.3 servicios proporcionados por otras organizaciones y G.RM gestión de riesgos.

Artículo 28 ausencia de DPA con la gestoría. La medida correctora es firmar un contrato de encargo de tratamiento con la gestoría que incluya las cláusulas mínimas del artículo 28: objeto y duración del tratamiento, naturaleza y finalidad, tipo de datos y categorías de interesados, obligaciones y derechos del responsable, y compromiso de confidencialidad y seguridad por parte de la gestoría. Salvaguarda Magerit asociada E.3 y E.4 personal subcontratado.

Artículo 32 FTP sin cifrado. La medida correctora es sustituir el acceso FTP por SFTP o FTPS implementando cifrado en tránsito para todas las transferencias de datos de RRHH con la gestoría, y cifrar los archivos de datos personales también en reposo antes de la transferencia. Salvaguarda Magerit asociada COM.C y D.C.

Artículo 32 backups sin cifrar. La medida correctora es implementar cifrado de los backups almacenados en el NAS QNAP y establecer un procedimiento de verificación periódica de restauración con frecuencia mínima trimestral y registro documentado de cada prueba realizada. Salvaguarda Magerit asociada D.A y D.C.

Artículo 32 ausencia de MFA. La medida correctora es activar la autenticación multifactor en Microsoft 365 para todas las cuentas, en TeamViewer para todos los técnicos con cuentas individuales y en la VPN corporativa para empleados y autónomos. Salvaguarda Magerit asociada H.IA.

Artículo 25 privacidad por diseño. La medida correctora es revisar la configuración de Microsoft 365 activando las políticas de DLP para detectar y bloquear compartición de datos personales fuera de la organización, y establecer una política de clasificación de la información que distinga qué documentos contienen datos personales y qué controles les aplican. Salvaguarda Magerit asociada H.AC y H.tools.DLP.

Artículo 33 ausencia de procedimiento de notificación de brechas. La medida correctora es documentar un procedimiento de gestión de brechas de seguridad que establezca cómo BERMA detecta, evalúa, contiene y notifica una brecha a la AEPD en el plazo de 72 horas, con los roles y responsabilidades asignados y una

plantilla de notificación basada en el formulario oficial de la AEPD. Salvaguarda Magerit asociada H.IR gestión de incidencias y BC.DRP.

Artículos 15 al 22 ausencia de procedimiento de derechos. La medida correctora es documentar un procedimiento interno para atender solicitudes de derechos de los interesados que establezca el canal de recepción, el plazo de respuesta de un mes, el responsable de tramitarlas y cómo verificar la identidad del solicitante antes de responder.

NIS2 APLICADO A BERMA

Antes de entrar en las medidas es necesario determinar si NIS2 aplica directamente a BERMA porque no es una obligación universal como el RGPD sino que depende del sector y el tamaño.

NIS2 transpuesta en España mediante la futura Ley de Coordinación de Ciberseguridad, pendiente de aprobación definitiva en 2024 y 2025, establece dos categorías de entidades obligadas. Entidades esenciales que son las de sectores críticos como energía, agua, transporte y salud con más de 250 empleados o más de 50 millones de euros de facturación. Entidades importantes que son las de sectores relevantes con más de 50 empleados o más de 10 millones de euros de facturación.

BERMA con 19 empleados y 2,3 millones de facturación queda por debajo de los umbrales de tamaño para ser considerada entidad esencial o importante de forma directa.

Sin embargo, hay un artículo de NIS2 que sí le aplica de forma indirecta y que es el más relevante para el portfolio. El **artículo 21** de NIS2 obliga a las entidades esenciales e importantes a gestionar los riesgos de ciberseguridad de su cadena de suministro, incluyendo a sus proveedores de servicios. BERMA presta servicios de mantenimiento remoto de sistemas de control industrial a clientes que pueden ser operadores de servicios esenciales en los sectores de agua y química. Esos clientes están obligados por NIS2 a evaluar y gestionar los riesgos de sus proveedores de servicios críticos. Esto significa que aunque BERMA no esté directamente obligada, sus clientes le van a exigir evidencias de sus controles de seguridad para cumplir con su propia obligación bajo el **artículo 21**.

Las medidas correctoras que BERMA debería adoptar para ser un proveedor aceptable bajo NIS2 desde la perspectiva de sus clientes son las siguientes.

Implementar una política formal de seguridad de la información documentada que cubra la gestión de riesgos, la gestión de incidentes, la continuidad de

negocio y la seguridad en la cadena de suministro. Esto es lo que cualquier cliente obligado por NIS2 le va a pedir como evidencia mínima.

Establecer el procedimiento de notificación de incidentes que afecten a los sistemas de sus clientes, con plazos alineados con los que NIS2 exige a esos clientes frente a las autoridades nacionales, que son notificación inicial en 24 horas e informe completo en 72 horas.

Implementar segmentación de red IT/OT que es el control técnico más crítico para un proveedor de servicios de mantenimiento de sistemas de control industrial y el que cualquier auditor de un cliente del sector agua o química va a verificar en primer lugar.

Gestionar el acceso remoto a sistemas de clientes con autenticación robusta, registro de sesiones y principio de mínimo privilegio, que cubre directamente los problemas de TeamViewer que hemos identificado en el análisis Magerit.

RGPD APLICADO A BERMA — ANÁLISIS COMPLETO

BERMA COMO RESPONSABLE DEL TRATAMIENTO

Artículo 4. Define los conceptos base. BERMA es responsable del tratamiento porque determina los fines y medios del tratamiento de datos personales de sus empleados, clientes y proveedores. La gestoría es encargada del tratamiento porque procesa datos por cuenta de BERMA. Esta distinción es fundamental para todo lo que viene después.

Artículo 6. Establece la base legal que legitima cada tratamiento. Para los datos de empleados la base es 6.1.b ejecución de contrato laboral y 6.1.c obligación legal para las cotizaciones a la Seguridad Social y las retenciones fiscales. Para los datos de clientes y proveedores la base es 6.1.b ejecución del contrato mercantil. BERMA no ha documentado estas bases legales en ningún registro formal, lo que constituye un incumplimiento indirecto aunque los tratamientos en sí sean legítimos.

INCUMPLIMIENTOS DIRECTOS Y ACTIVOS

Artículo 30. Obligación de mantener el Registro de Actividades de Tratamiento. BERMA no tiene ningún RAT documentado. Es un incumplimiento activo e inmediato independientemente de cualquier otra circunstancia. El RAT debe incluir todos los tratamientos que realiza BERMA: gestión de nóminas, gestión de clientes, gestión de proveedores y cualquier otro. Vinculado directamente al activo D5 datos personales de empleados y al activo D6 datos de clientes y proveedores.

Artículo 28. Obligación de formalizar un contrato de encargo de tratamiento con todo proveedor que acceda a datos personales por cuenta de BERMA. La gestoría accede a datos de nóminas, IBAN y números de Seguridad Social de los empleados sin ningún contrato DPA firmado. Es el incumplimiento más grave y más fácil de acreditar por la AEPD. Vinculado directamente al activo 6 gestoría externa con amenazas E.19 y A.11.

Artículo 32. Obligación de implementar medidas técnicas y organizativas apropiadas para garantizar la seguridad de los datos personales. Los incumplimientos concretos de BERMA bajo este artículo son los siguientes. La transferencia de datos de RRHH mediante FTP sin cifrado viola la obligación de garantizar la confidencialidad en tránsito. Los backups sin cifrar del NAS violan la obligación de garantizar la confidencialidad en reposo. La ausencia de MFA en Microsoft 365 que almacena datos de clientes y comunicaciones con empleados viola la obligación de garantizar acceso autorizado. La ausencia de pruebas de restauración de backups viola la obligación de garantizar la disponibilidad y resiliencia de los sistemas. Vinculado a los activos 6 gestoría, 7 backup y 9 Microsoft 365.

Artículo 25. Privacidad desde el diseño y por defecto. BERMA no ha incorporado ningún criterio de protección de datos en el diseño de sus sistemas de información ni ha configurado sus herramientas con los ajustes más restrictivos por defecto. Microsoft 365 sin DLP y sin MFA es el ejemplo más directo. Vinculado al activo 9 Microsoft 365.

Artículo 5.1.f. Principio de integridad y confidencialidad. Todo tratamiento de datos personales debe realizarse garantizando su seguridad mediante medidas técnicas y organizativas apropiadas. Este artículo es el paraguas general bajo el que caen todos los incumplimientos técnicos de seguridad que afectan a datos personales. Vinculado a los activos 6, 7 y 9.

RIESGOS DE INCUMPLIMIENTO ANTE UN INCIDENTE

Artículo 33. Obligación de notificar a la AEPD cualquier brecha de seguridad que afecte a datos personales en un plazo máximo de 72 horas desde que BERMA tenga conocimiento de ella. BERMA no tiene ningún procedimiento de gestión de incidentes documentado ni ningún sistema de detección que le permita conocer cuándo se ha producido una brecha. Si ocurriera un incidente hoy, BERMA incumpliría este artículo por incapacidad técnica y organizativa para detectarlo y notificarlo en plazo. Vinculado a todos los activos con datos personales y especialmente al activo 7 backup donde la ausencia de monitorización hace indetectable una brecha.

Artículo 34. Si la brecha supone un alto riesgo para los derechos y libertades de los afectados, BERMA debe comunicárselo también a los propios empleados afectados sin dilación indebida. Sin procedimiento de gestión de incidentes esto es igualmente imposible de cumplir. Vinculado a D5 datos personales de empleados.

Artículo 82. Responsabilidad y derecho a indemnización. Si un empleado o cliente sufriera daños como consecuencia de un incumplimiento del RGPD por parte de BERMA, tiene derecho a reclamar indemnización directamente a la empresa. En el caso de la brecha FTP de datos de nóminas, cualquier empleado afectado podría reclamar individualmente.

DERECHOS DE LOS INTERESADOS CON RIESGO DE INCUMPLIMIENTO

Artículos 15 al 22. Los empleados y clientes de BERMA tienen derechos de acceso, rectificación, supresión, limitación del tratamiento, portabilidad y oposición sobre sus datos personales. BERMA no tiene ningún procedimiento documentado para atender estas solicitudes ni plazos definidos para responderlas. Si un empleado ejerciera su derecho de acceso bajo el artículo 15 solicitando saber qué datos tiene BERMA sobre él, la empresa no podría responder adecuadamente en el plazo de un mes que exige el artículo 12 porque no tiene el RAT del artículo 30 que le permitiría identificar todos los tratamientos que afectan a ese empleado.

MICROSOFT 365 COMO PROCESADOR EN TERCEROS PAÍSES

Artículo 44 y siguientes. Microsoft puede procesar datos en servidores fuera del Espacio Económico Europeo dependiendo de la configuración de la suscripción de BERMA. Con una suscripción Business Basic sin configuración específica de residencia de datos, BERMA debe verificar si Microsoft actúa bajo las cláusulas

contractuales tipo de la Comisión Europea como mecanismo de transferencia internacional. Microsoft tiene su propio DPA estándar pero BERMA debe haberlo aceptado formalmente y verificar que cubre los datos que realmente almacena en la plataforma. Vinculado al activo 9 Microsoft 365.

RÉGIMEN SANCIONADOR

Artículo 83.4. Sanciones de hasta 10 millones de euros o el 2 por ciento de la facturación global anual para infracciones de los artículos 25 al 39. Esto cubre los incumplimientos de BERMA en **artículos 25** privacidad por diseño, **28** contrato con gestoría, **30** RAT, **32** seguridad y **33** notificación de brechas. Para BERMA con una facturación de 2,3 millones de euros el techo sería 46.000 euros por el cálculo del 2 por ciento, aunque la AEPD puede aplicar el importe fijo de hasta 10 millones si es mayor.

Artículo 83.5. Sanciones de hasta 20 millones de euros o el 4 por ciento de la facturación global para infracciones de los **artículos 5 y 6**. Si la AEPD determinara que BERMA viola el principio de integridad y confidencialidad del **artículo 5.1.f** de forma sistemática por la acumulación de deficiencias técnicas documentadas, el régimen sancionador aplicable sería este nivel superior. Para BERMA el techo sería 92.000 euros por el cálculo del 4 por ciento.

RESUMEN DE VINCULACIÓN ACTIVOS CON ARTÍCULOS

Activo 6 gestoría externa: **artículos 28, 32 y 5.1.f** de forma directa. Artículos 33 y 34 como riesgo ante incidente.

Activo D5 datos personales empleados: **artículos 5, 6, 13, 30 y 32** de forma directa. **Artículos 15 al 22** como obligaciones de derechos. **Artículos 33 y 34** como riesgo ante incidente.

Activo 7 backup: **artículos 32 y 5.1.f** de forma directa. Artículo 33 como riesgo ante incidente por indetectabilidad de brechas.

Activo 9 Microsoft 365: **artículos 28, 25, 32 y 44** de forma directa.

Activo D6 datos clientes y proveedores: **artículos 5, 6 y 30** de forma directa. **Artículos 15 al 22** como obligaciones de derechos.